German International University (GIU)

Faculty of Informatics and Computer Science
Department: IT Security
Course: Business Continuity and Risk Management

Risk Assessment and Business Impact Analysis

for Identity and Access Management System

using NIST SP 800-30

Group Members:

Abdelmonem Sayed - 13006494

Ebram Nageh – 13006318

Ebram Hany - 13002244

Partenia bassem – 13005493

Spring 2026

A. System Description

A.1 System Purpose and Functions

An Identity and Access Management (IAM) system is designed to provide centralized authentication, authorization, and access control across an organization. It ensures that only authorized users can access systems, applications, and data resources.

IAM systems play a critical role in maintaining security and operational efficiency by managing digital identities and controlling access to sensitive resources. Examples of such systems include Microsoft Active Directory and Azure Active Directory.

The main functions of the IAM system include:

- User authentication (verifying user identity during login)
- Authorization and access control based on roles and permissions
- Management of user accounts and role assignments
- Enforcement of security policies
- Monitoring and logging user activities
- Integration with enterprise applications and services

A.2 Users and Stakeholders

The IAM system is used by various stakeholders within the organization, including:

- Employees and end users who access systems and applications
- IT administrators responsible for managing user accounts
- Security teams who monitor access and enforce policies
- System and network administrators
- Management ensuring business continuity and operational efficiency
- Auditors and compliance officers reviewing access logs and policies

A.3 Data Processed

The IAM system processes sensitive and critical data, including:

- User credentials (usernames and passwords)
- Personally Identifiable Information (PII) such as names and email addresses
- Access permissions and role assignments
- Authentication and login logs

- Security policies and configurations
- Organizational and directory information

A.4 Business Processes Dependent on the System

Several critical business processes depend on the IAM system, such as:

- User login and access to systems
- Access to enterprise applications such as email, ERP, and CRM systems
- Administrative and IT operations
- Compliance and auditing processes
- Security monitoring and incident response
- Communication and collaboration tools

Any failure in the IAM system may prevent users from accessing essential resources, leading to major disruptions in business operations. As a result, this highlights the critical importance of IAM systems in maintaining both security and business continuity.

B. Risk Management Methodology

B.1 Selected Standard

In this project, the NIST SP 800-30 framework is used to conduct the information security risk assessment. NIST SP 800-30 provides a structured and systematic approach for identifying, analyzing, and evaluating risks in information systems.

B.1.1 Justification for Using NIST SP 800-30

NIST SP 800-30 is particularly suitable for analyzing risks in Identity and Access Management (IAM) systems due to its clear and practical methodology. IAM systems, such as those used for authentication and access control, are critical components of organizational security, and they require a detailed evaluation of potential threats and vulnerabilities.

The framework allows for:

- Systematic identification of assets, threats, and vulnerabilities
- Evaluation of risk based on likelihood and impact
- Prioritization of risks based on their severity
- Development of appropriate mitigation strategies

Additionally, NIST SP 800-30 is widely used in real-world organizations and aligns well with security best practices, making it highly relevant for analyzing systems like IAM that handle sensitive user data and access control mechanisms.

B.1.2 Application of the Framework

The NIST SP 800-30 framework is applied in this project through the following steps:

- Identification of system assets (e.g., user accounts, authentication servers)
- Identification of potential threats (e.g., unauthorized access, credential theft)
- Identification of vulnerabilities (e.g., weak passwords, lack of multi-factor authentication)
- Assessment of likelihood and impact of each risk
- Determination of overall risk level

- Recommendation of appropriate risk treatment strategies

These steps are used to build a structured risk register for the IAM system, ensuring a comprehensive and standardized risk assessment process.

B.2 Risk Register

According to information security risk management principles, risk arises when a threat exploits a vulnerability in an asset, leading to a potential impact on the organization. The following risk register is developed based on the NIST SP 800-30 framework and identifies key risks associated with the Identity and Access Management (IAM) system. The analysis reflects real-world scenarios in systems such as Microsoft Active Directory and Azure Active Directory.

likelihood Scale (NIST SP 800-30, Section 3.3 – semi-quantitative)

Likelihood Level	Probability Range	Numeric Score
Rare	< 10%	1
Unlikely	10% – 24%	2
Possible	25% – 49%	3
Likely	50% – 79%	4
Almost Certain	80% – 100%	5

Impact Scale

Impact Level	Numeric Score
Minor	1
Moderate	2
Major	3
Catastrophic	4

Risk Classification Matrix (Likelihood × Impact)

Likelihood \ Impact	Minor (1)	Moderate (2)	Major (3)	Catastrophic (4)
Rare (1)	1	2	3	4
Unlikely (2)	2	4	6	8
Possible (3)	3	6	9	12
Likely (4)	4	8	12	16
Almost Certain (5)	5	10	15	20

Risk Classification Thresholds (Risk Appetite Statement)

Following NIST SP 800-39, the organisation's risk tolerance is defined as:

Risk Score	Classification	Action

1 – 5	Low	Accept or monitor (within risk appetite)
6 – 11	Medium	Requires mitigation plan (managed risk)
12 – 20	High	Immediate mitigation required (outside risk appetite)

Risk Register Table

Asset	Threat	Vulnerability	Existing Controls	Likelihood	Impact	Risk Score	Classification	Consequences	Treatment
User Accounts	Unauthorized access	Weak passwords, no MFA	Password policy	Likely (4)	Major (3)	12	High	Unauthorized system access	Mitigation (enforce MFA, strong password policy)
Admin Accounts	Privilege escalation	Excessive privileges	RBAC	Likely (4)	Catastrophic (4)	16	High	Full domain compromise	Mitigation (least privilege, PAM)
Authentication Server	DoS attack	No redundancy	Firewall	Possible (3)	Major (3)	9	Medium	Service downtime	Mitigation (failover, load balancing)
IAM Database	Data breach	No encryption	Access control	Possible (3)	Major (3)	9	Medium	Exposure of sensitive data	Mitigation (encryption at rest and in transit)
GPO	Misconfiguration	No review process	Admin control	Possible (3)	Moderate (2)	6	Medium	Incorrect permissions	Mitigation (change management)
Authentication Logs	Log tampering	No monitoring	Basic logging	Possible (3)	Moderate (2)	6	Medium	Loss of audit trail	Mitigation (deploy SIEM)
Azure AD Accounts	Phishing attack	Lack of user awareness	Password login	Likely (4)	Major (3)	12	High	Account takeover	Mitigation (MFA + awareness training)
Backup System	Data loss	No backup schedule	Manual backup	Unlikely (2)	Major (3)	6	Medium	Loss of critical data	Mitigation (automated backup)
Network Access	Unauthorized access	Poor segmentation	Firewall	Possible (3)	Major (3)	9	Medium	Internal attack spread	Mitigation (network segmentation)
Legacy Authentication	Credential attack	Outdated protocols	Basic auth enabled	Unlikely (2)	Moderate (2)	4	Low	Minor security exposure	Acceptance (monitored)

Third-party Identity Integration	External compromise	Dependency on third-party	Vendor controls	Possible (3)	Major (3)	9	Medium	External breach impact	Mitigation (contractual security + monitoring)
Remote Access	Unauthorized login	Open remote access	VPN	Likely (4)	Major (3)	12	High	Full system exposure	Avoidance (disable unnecessary remote access)

The identified risks highlight the critical importance of securing IAM systems, as they directly impact authentication, access control, and overall organizational security. Appropriate risk treatment strategies are applied based on risk severity, ensuring that high and critical risks are mitigated or avoided, medium risks are mitigated or transferred, and low risks are accepted within the organization's risk tolerance.

(C) Business Impact Analysis (BIA)

C.1 Weight Analysis Table

Business Impact Analysis (BIA) is used to evaluate the impact of system disruption on business operations and to determine recovery priorities. It helps organizations identify critical systems and decide which systems must be restored first in case of a failure.

Since not all systems can be recovered at the same time, BIA is essential for prioritizing systems based on their importance to business continuity.

Criteria	Weight	Score (1–5)	Weighted Score	Justification

Revenue Dependency	0.15	3	0.45	IAM does not directly generate revenue, but enables revenue systems. Lowest priority.
Customer Impact	0.30	5	1.50	Customers cannot access services without authentication. Second highest.
Regulatory Exposure	0.20	4	0.80	IAM is critical for audit trails and access compliance (GDPR, SOX). Medium priority.
Operational Dependency	0.35	5	1.75	All business systems depend on IAM; failure halts operations. Highest priority.
Total	1.00		**4.50 / 5**	

The weights are derived from the organisation's mission priority: operational continuity > customer trust > regulatory compliance > revenue. IAM is a prerequisite for all other systems, so operational dependency receives the highest weight.

Interpretation: A weighted score of 4.50 out of 5 indicates very high criticality – the IAM system is a single point of failure requiring aggressive recovery objectives.

The IAM system has a moderate impact on revenue, as it does not directly generate income but enables access to business systems. However, it has a very high impact on customer access, since users depend on it to log in and access services.

From a regulatory perspective, IAM systems play an important role in ensuring compliance with access control and data protection requirements. The operational dependency is extremely high, as most systems rely on authentication and authorization to function properly.

The final weighted score of 4.50 out of 5 indicates that the IAM system is highly critical to the organization.

Each recovery objective is directly derived from the BIA weights, scores, and risk register entries.

C.2 Business Continuity Metrics

In order to evaluate acceptable downtime and recovery requirements of the Identity and Access Management (IAM) system, the following Business Continuity parameters are defined.

The recovery objectives are derived from the risk analysis in Part B, where critical risks such as unauthorized access, privilege escalation, authentication failure, and system downtime were identified as high or critical. Since IAM is a single point of failure, strict recovery constraints are required to ensure business continuity.

C.2.1 Recovery Time Objective (RTO)

RTO = 1 hour

he BIA's Operational Dependency (weight 0.35, score 5) contributes 1.75 to the total criticality. A disruption longer than 1 hour would halt all dependent systems (email, ERP, CRM), causing irreversible operational damage. The risk register lists "Authentication Server DoS" (score 9, Medium) and "Remote Access" (score 12, High) – both require fast recovery within 1 hour.

C.2.2 Recovery Point Objective (RPO)

RPO = 15 minutes

The BIA's Customer Impact (score 5) and Regulatory Exposure (score 4) demand very low data loss. IAM data changes frequently (password resets, group updates). Loss beyond 15 minutes would cause (a) customer access denial (Customer Impact weight 0.30 × 5 = 1.50) and (b) loss of audit trail (risk register: "Authentication Logs" score 6, Medium). The 15-minute RPO ensures at most one password change or group update is lost.

C.2.3 Work Recovery Time (WRT)

WRT = 1 hour

After technical restoration, the BIA's Operational Dependency (score 5) requires full validation of authentication, replication, and integration with dependent systems. The risk register's "GPO Misconfiguration" (score 6, Medium) and "Legacy Authentication" (score 4, Low) must be checked. The WRT of 1 hour allows these checks without exceeding the MTD.

C.2.4 Maximum Tolerable Downtime (MTD)

MTD = 4 hours

The total BIA weighted score of 4.50/5 indicates very high criticality. MTD is set as RTO + WRT + 2 hours safety margin = 1 + 1 + 2 = 4 hours. Beyond 4 hours, the cumulative impact from all BIA criteria (Revenue 0.45, Customer 1.50, Regulatory 0.80, Operational 1.75 =

4.50) would exceed the organisation's tolerance. The risk register's "Full domain compromise" (score 16, High) would become irreversible after 4 hours.

C.3 Business Impact :

The Identity and Access Management (IAM) system is a mission-critical infrastructure component responsible for authentication and authorization across the organization.

Based on the risk register in Part B, multiple high and critical risks were identified, including unauthorized access, privilege escalation, authentication server failure, and data breach. These risks directly affect system availability, confidentiality, and integrity, making IAM a single point of failure for all enterprise services.

Any disruption to the IAM system results in immediate denial of access to dependent systems such as enterprise applications, communication platforms, and administrative tools, leading to operational paralysis.

Therefore, strict recovery objectives and continuity requirements are essential to ensure minimal downtime, data protection, and business continuity.

C.4 Consistency Check

To ensure alignment with business continuity principles, the following relationships are verified:

- RPO (15 minutes) < RTO (1 hour)
- RTO (1 hour) < MTD (4 hours)
- WRT (1 hour) ensures full operational recovery, including system validation, service synchronization, and user resumption of activities.

This confirms that recovery objectives are consistent, realistic, and aligned with organizational tolerance for downtime and data loss.

(Milestone 2) Continuity & Recovery Planning

A Continuity Strategy

A.1 Continuity Strategy Overview

Based on the results of Milestone 1, the Identity and Access Management (IAM) system was identified as a highly critical system with a score of 4.50/5. It is also considered a single point of failure because all users and many business systems depend on it for authentication and authorization.

The risk analysis showed that several threats could seriously affect the IAM environment, especially unauthorized access, privilege escalation, system downtime, phishing, and data loss. Because of this, the continuity strategy must ensure that the system remains available, recoverable, and protected against both technical failures and security incidents.

To achieve this, the strategy is built on multiple layers of protection. These layers include backup and replication, RAID for storage resilience, multiple domain controllers for high availability, a recovery site for major disasters, and temporary workarounds that allow limited operations during an outage.

The design of this strategy is guided by the recovery objectives defined in Milestone 1. The RTO of 1 hour requires fast failover and recovery. The RPO of 15 minutes requires very limited data loss. The WRT of 1 hour allows time for validation and stabilization after restoration. The MTD of 4 hours represents the maximum period the organization can tolerate without IAM services.

A.2 Backup Strategy

A.2.1 Backup Types

For the IAM system, two main backup types are used: full backup and incremental backup.

A **full backup** captures the entire Active Directory system state, including the AD database (NTDS.dit), SYSVOL, Group Policy Objects (GPOs), DNS data, certificates, and other important configuration information. Its main advantage is that it provides a complete restore point and makes recovery simpler because only one backup set is needed.

However, full backups require more storage space and take more time to complete. For that reason, using them every day would not be efficient.

An **incremental backup** captures only the changes made since the last backup. This makes it faster and more storage-efficient. In IAM systems, daily changes usually include password resets, account modifications, and group membership updates, which are relatively small compared to the full directory structure. Because of this, incremental backup is suitable for daily use.

The disadvantage of incremental backup is that recovery becomes more complex, because the latest full backup and all following incremental backups are needed to restore the system.

A.2.2 Backup Schedule

Day	Backup Type	Scope	Window	Retention
Sunday	**Full Backup**	Complete System State (NTDS.dit, SYSVOL, DNS, GPOs, Certificates)	02:00 – 04:00	4 weeks
Monday	Incremental	Changes since last backup	02:00 – 02:30	2 weeks
Tuesday	Incremental	Changes since last backup	02:00 – 02:30	2 weeks
Wednesday	Incremental	Changes since last backup	02:00 – 02:30	2 weeks
Thursday	Incremental	Changes since last backup	02:00 – 02:30	2 weeks

Friday	Incremental	Changes since last backup	02:00 – 02:30	2 weeks
Saturday	Incremental	Changes since last backup	02:00 – 02:30	2 weeks

This schedule is suitable because Active Directory usually experiences frequent but relatively small updates. The backup schedule provides recovery points for disaster recovery and logical corruption scenarios. In addition, Active Directory replication between domain controllers helps reduce the risk of recent data loss, while backups remain necessary for full restoration and point-in-time recovery.

A.2.3 Backup Storage and Security

To improve resilience, the backup strategy follows the **3-2-1 rule**, which means:

- keeping three copies of data,
- storing them on two different media types,
- and maintaining one copy offsite.

The backup storage is organized as follows:

- **Primary copy:** stored on an on-premises backup server for fast access.
- **Offsite copy:** replicated to a geographically separate location to protect against site-level disasters.
- **Cloud copy:** stored in encrypted form in cloud storage such as Microsoft Azure Backup or AWS S3 for an additional layer of protection.

All backup data is encrypted at rest using AES-256 and transmitted securely using TLS. Access to backups is restricted through role-based access control, and backup operations are logged for accountability and audit purposes.

A.3 Storage & RAID Design

A.3.1 RAID Level Selection

For the production domain controllers, **RAID 1** is selected. RAID 1 mirrors data across two disks, so if one disk fails, the other continues operating without data loss. This makes it suitable for critical systems such as domain controllers, where simplicity and reliability are more important than storage efficiency.

RAID 1 is appropriate for this environment because:

- it provides straightforward redundancy,
- it supports good read performance,
- rebuild time is relatively simple,
- and Active Directory does not usually require very large storage capacity.

For the backup server, **RAID 6** is selected. RAID 6 can tolerate two simultaneous disk failures, which makes it a stronger option for backup storage, where data preservation is essential.

A.3.2 RAID Configuration Summary

Component	RAID Level	Disks	Usable Capacity	Fault Tolerance
Primary DC (DC1)	RAID 1	2 × 1 TB SSD	1 TB	1 disk failure
Secondary DC (DC2)	RAID 1	2 × 1 TB SSD	1 TB	1 disk failure
Backup Server	RAID 6	6 × 4 TB HDD	16 TB	2 simultaneous failures

A.3.3 RAID vs Backup

It is important to distinguish between RAID and backup.

RAID protects against hardware failure, especially disk failure, by keeping data available in real time. However, RAID does not protect against logical problems such as accidental deletion, corruption, ransomware, or software errors.

Backup, on the other hand, protects against these logical and disaster-related scenarios by preserving earlier copies of the data that can be restored later.

For this reason, both RAID and backup are needed. They serve different purposes and should be used together as part of a defense-in-depth strategy.

A.4 High Availability and Failover

A.4.1 Multi-Domain Controller Architecture

To reduce the single point of failure identified in Milestone 1, the IAM environment should use two domain controllers instead of one.

The **Primary Domain Controller (DC1)** handles normal directory services and hosts the FSMO roles.
The **Secondary Domain Controller (DC2)** maintains a synchronized copy of the directory and can continue serving authentication and directory requests if DC1 becomes unavailable.

Both domain controllers should be deployed on separate hardware with independent storage and network resources. This reduces the risk that a single hardware problem will affect both systems.

A.4.2 Replication

Active Directory uses multi-master replication, which means changes made on one domain controller are automatically replicated to the others. This helps keep data consistent across the environment.

Under normal operating conditions, replication happens frequently enough to support the required RPO of 15 minutes. However, replication should not be considered a replacement for backup, because it does not provide point-in-time recovery.

A.4.3 Failover Mechanism

If DC1 becomes unavailable, clients can continue authentication through DC2. Domain controllers are discovered through DNS SRV records, so clients can automatically connect to an available DC.

In this case, service continuity can still be maintained with **minimal disruption**. If DC1 remains unavailable for an extended period, the organization may decide to seize FSMO roles on DC2, depending on the severity and expected duration of the outage.

At the same time, monitoring and alerting should notify administrators so they can investigate the root cause and repair or replace the failed server.

A.5 Recovery Site Strategy

D.5.1 Site Type Selection

Site Type	Equipment	Data Currency	Activation Time	Cost
Hot Site	Fully operational mirror	Real-time replication	Minutes	Very High
Warm Site	Pre-provisioned hardware	Daily backup copies	1 – 4 hours	Moderate
Cold Site	Empty facility	None	Days – weeks	Low

A.5.2 Justification for Warm Site

A **Warm Site** is selected as the most suitable option for this project.

This choice provides a good balance between recovery capability and cost. A hot site would provide faster recovery, but it would be expensive and may not be justified because the dual-domain-controller design already handles most normal failures. A cold site would be cheaper, but recovery would take too long and may not meet the MTD.

A warm site can support the required recovery objectives if pre-provisioned hardware is already prepared, the operating system is installed, and the AD DS role is ready. Under these conditions, recovery within the required timeframe becomes realistic.

A.5.3 Warm Site Specifications

Attribute	Specification
Geographic Separation	≥ 50 km from primary facility
Server Hardware	Pre-provisioned, compatible hardware with RAID 1
Network	Dedicated WAN link + VPN failover
Operating System	Windows Server (matching version), pre-installed
AD DS Role	Installed but not promoted
Backup Access	Daily replication of backups from offsite storage
Target Activation	45 – 60 minutes
Testing	Quarterly failover drill

A.6 Workaround Strategy

During a complete IAM outage — before the recovery site is activated — the following workarounds maintain minimum operational capability:

A.6.1 Emergency Administrator Accounts

Pre-configured **local administrator accounts** on critical servers authenticate against the local SAM database, not Active Directory, and remain functional during AD outage. Credentials are stored in a sealed physical safe and an encrypted offline vault (KeePass on encrypted USB). Passwords are rotated every 90 days.

A.6.2 Cached Credentials

Windows can cache previously used domain credentials locally. This allows some users to log in to their workstations even if Active Directory is temporarily unavailable.

A.6.3 Manual Approval Processes

1. Employee contacts supervisor via phone or personal email to request access.
2. Supervisor verifies against the pre-distributed **offline access control list**.
3. Approved requests are communicated to IT Help Desk, which provisions temporary local access.
4. All temporary grants are logged manually with timestamp, requestor, approver, and system.
5. Upon IAM restoration, all temporary access is reviewed and revoked as appropriate.

(E) Recovery Procedures

E.1 Overview

The recovery procedures define a structured, repeatable process for restoring full IAM services. These procedures satisfy the **RTO of 1 hour**, the **RPO of 15 minutes**, the **WRT of 1 hour**, and the **MTD of 4 hours**. Each step is assigned to a responsible role and bounded by a target duration.

E.2 Step-by-Step Recovery Process

Step 1 - Detect Failure

The monitoring infrastructure (SCOM, Nagios, or SIEM) continuously monitors domain controller health. Failure is detected when LDAP bind, DNS resolution, and Kerberos authentication probes fail for three consecutive intervals, triggering a **P1 alert within 90 seconds**. The on-call engineer performs initial triage within 5 minutes:

Level	Condition	Response
1	Single DC failed; second DC operational	Automatic failover verify and monitor
2	Both DCs failed; backup data intact	Restore from backup on available hardware
3	Site-level disaster; primary site lost	Activate warm recovery site

4	Security breach / ransomware	Isolate → investigate → restore from clean backup

Target: ≤ 5 minutes. Owner: NOC / On-Call Engineer.

Step 2 - Activate Failover

Level 1: Failover is automatic via DNS. Verify DC2 is processing requests; seize FSMO roles if needed.
Level 2: Provision replacement DC; prepare for backup restoration.
Level 3: Contact recovery site team; update network routing; retrieve latest offsite backup.
Level 4: Disconnect affected DCs from network immediately. No restoration until forensic assessment confirms backup integrity.

Target: ≤ 10 minutes. Owner: AD Administrator / Incident Commander.

Step 3 - Restore from Backup

1. **Identify backup set:** Most recent full + subsequent incrementals (or last clean backup for security incidents).
2. **Boot into DSRM:** Start target server in Directory Services Restore Mode.
3. **Restore System State:** Restore NTDS.dit, SYSVOL, GPOs, DNS, certificates, and registry.
4. **Authoritative restore (if needed):** Use `ntdsutil` for specific objects that must override replication.
5. **Restart normally:** Allow AD replication to synchronize with surviving DCs.

Target: ≤ 25 minutes. Owner: Backup Administrator / AD Administrator.

Step 4 - Validate System

Before returning to production, comprehensive validation is performed (this corresponds to the **WRT of 1 hour**):

User Authentication Validation:

- Test domain logon from workstations across multiple network segments
- Verify Kerberos ticket issuance and renewal
- Test MFA integration if deployed

Access Control Validation:

- Verify GPO application (`gpresult /r`)
- Confirm security group memberships and resource access
- Test authorized and denied access scenarios

System Integration Validation:

- Verify authentication to all AD-dependent systems (email, VPN, ERP, web apps)
- Confirm DNS resolution for all domain resources
- Verify domain trust relationships
- Test LDAP connectivity from integrated applications

Replication Validation:

```
repadmin /replsummary
dcdiag /v
```

Target: ≤ 20 minutes active validation (within WRT). Owner: AD Administrator / QA.

Step 5 - Resume Normal Operations

1. **Revoke workaround access:** Remove all temporary grants; reset emergency account passwords.
2. **Restore FSMO roles:** Evaluate transferring roles back to original DC once stable.
3. **Notify stakeholders:** Issue "all clear" communication to all users and management.
4. **Enhanced monitoring:** Increase monitoring sensitivity for 72-hour observation period.
5. **Post-Incident Report:** Document root cause, timeline, actual RTO/RPO achieved, and lessons learned within 48 hours.

E.3 Recovery Timeline Summary

Phase	Target Duration	Cumulative	Owner
1. Detect Failure	≤ 5 min	5 min	Monitoring / NOC
2. Activate Failover	≤ 10 min	15 min	AD Administrator
3. Restore from Backup	≤ 25 min	40 min	Backup Admin

4. Validate System	≤ 20 min	60 min	AD Admin / QA
5. Resume Operations	—	—	Incident Commander
Total Recovery (RTO)		**≤ 60 minutes ✓**	
+ Validation (WRT)		**+ 1 hour = 2 hours total**	**Within 4-hour MTD ✓**

(C) System Architecture

C.1 Architecture Overview

The IAM/Active Directory architecture implements a multi-tier, fault-tolerant design that eliminates the single point of failure identified in Milestone 1. The following components comprise the complete continuity-ready infrastructure:

Component	Description	Continuity Role
End Users / Clients	Workstations, laptops, servers authenticating via Kerberos, LDAP, DNS	Consumers of IAM service
Primary DC (DC1)	Windows Server + AD DS, hosts 5 FSMO roles, RAID 1 (2×1TB SSD)	Primary authentication and directory services
Secondary DC (DC2)	Identical to DC1, active-active replication, independent hardware	Automatic failover; eliminates SPOF
DNS Round-Robin	Distributes authentication requests across DC1 and DC2	Load balancing and automatic redirection
Backup Server	RAID 6 (6×4TB HDD, 16TB usable), weekly full + daily incremental	Point-in-time recovery for disasters and corruption
Offsite Backup	AES-256 encrypted copy at facility ≥ 50 km away	Protection against site-level disasters
Cloud Backup	Azure Backup / AWS S3, AES-256, versioned, TLS 1.3	Infrastructure-independent tertiary copy

Warm Recovery Site	Pre-provisioned server, OS + AD DS role ready, daily backup sync	Site-level disaster recovery (activation ≤ 60 min)

C.2 Architecture Diagram

Figure 1 — IAM / Active Directory System Architecture

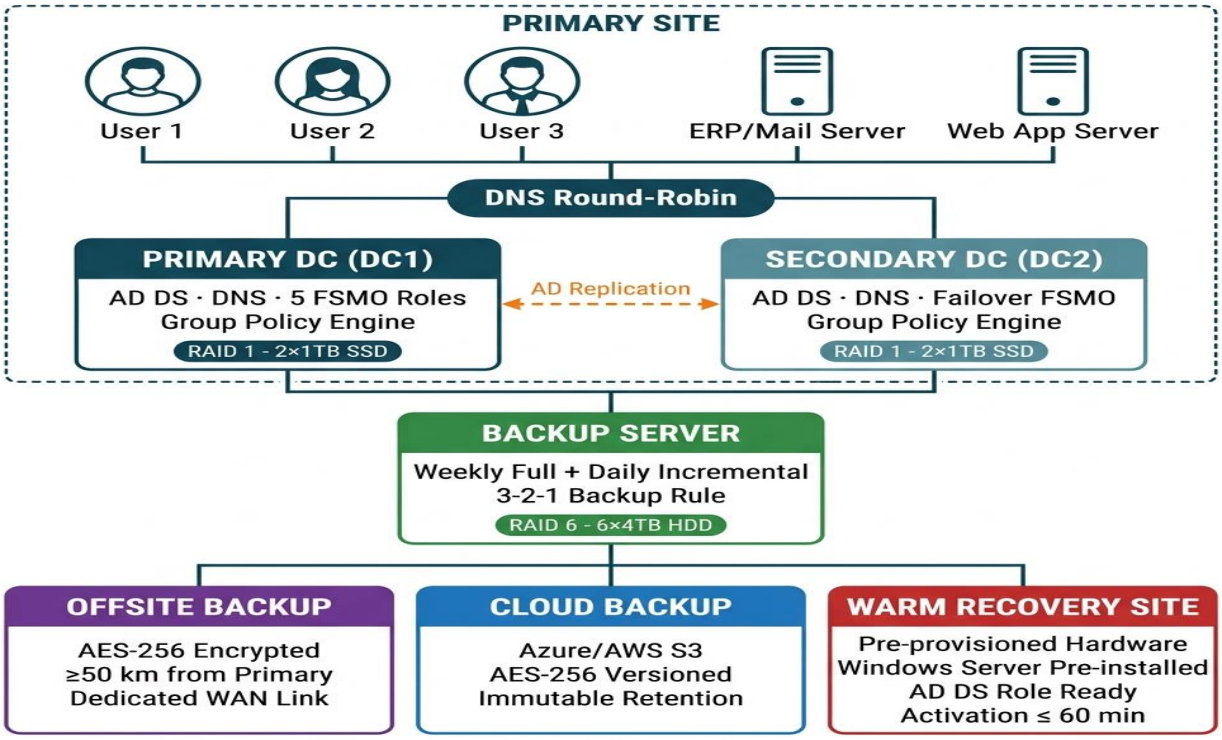
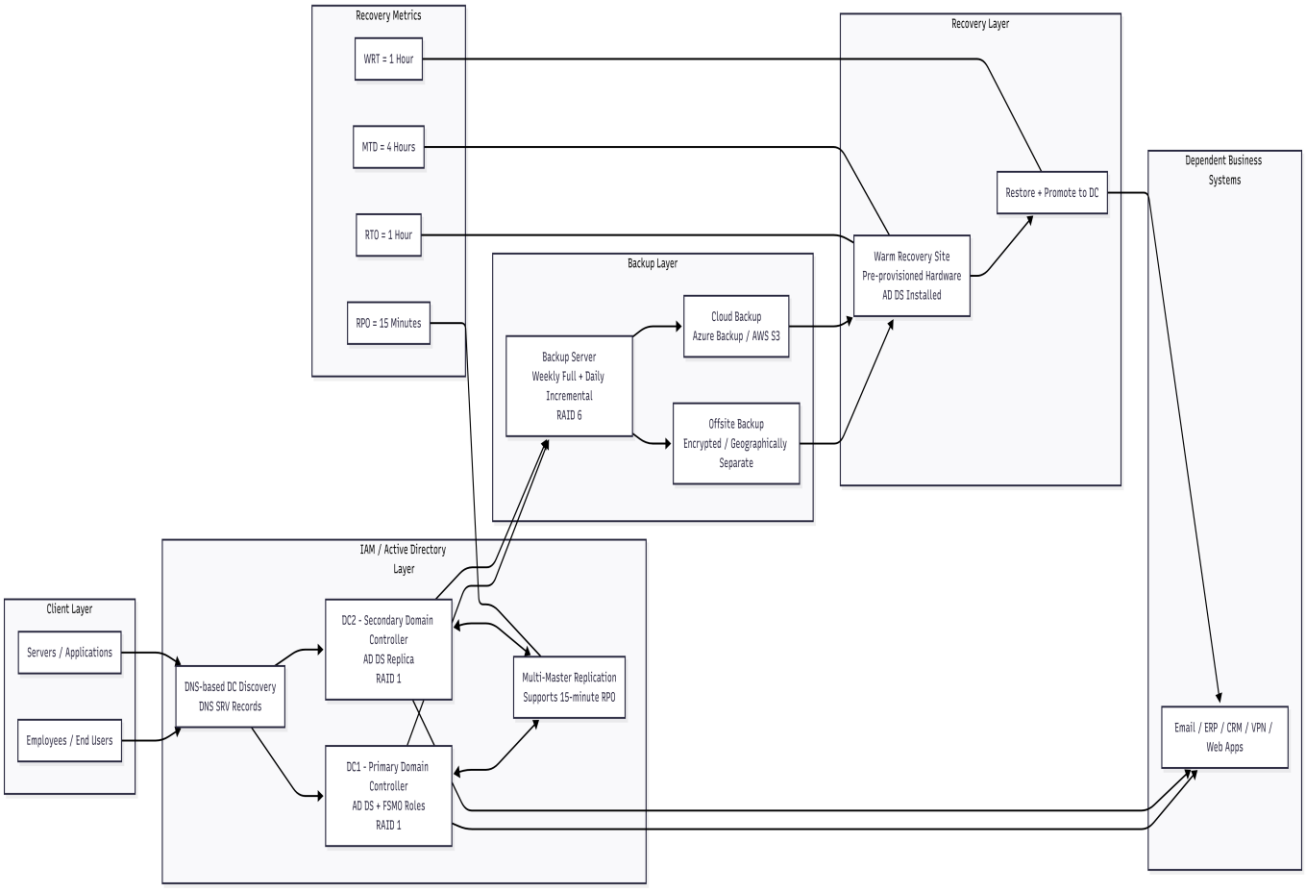


Figure 2 — IAM / Active Directory System Architecture



C.3 Data Flow Description

1. **Authentication Flow:** Users submit credentials via Kerberos/LDAP to DNS Round-Robin, which distributes requests to DC1 or DC2. The DC validates credentials and issues authentication tokens.
2. **Replication Flow:** Changes on either DC are replicated to the partner within seconds via AD multi-master replication, satisfying the 15-minute RPO.
3. **Backup Flow:** The Backup Server captures System State data, stores it on RAID 6, then replicates encrypted copies to offsite (via WAN) and cloud (via TLS 1.3).
4. **Recovery Flow:** In a disaster, the Warm Recovery Site retrieves the latest backup, restores the AD database, promotes the server to DC, and assumes primary identity services.

(D) Conclusion

This project presented a risk assessment, business impact analysis, and continuity and recovery plan for an Identity and Access Management system, using Microsoft Active Directory and Azure Active Directory as practical examples. The analysis was based on the NIST SP 800-30 framework.

Milestone 1 showed that the IAM system is highly critical, with a BIA score of **4.50 / 5**, and that it represents a major dependency for business operations. The risk assessment identified several important threats, including unauthorized access, privilege escalation, phishing, system failure, and data loss. The recovery objectives were defined as **RTO = 1 hour, RPO = 15 minutes, WRT = 1 hour, and MTD = 4 hours**.

Milestone 2 translated these findings into a practical continuity and recovery plan based on multiple layers of protection. These layers included backup strategy, RAID design, high availability through multiple domain controllers, a warm recovery site, and temporary workarounds during service outages.

Overall, the proposed design improves resilience, reduces the impact of outages, and supports business continuity by ensuring that the organization can restore IAM services within an acceptable time and with limited data loss.

References

National Institute of Standards and Technology. (2012). *SP 800-30 Rev. 1: Guide for Conducting Risk Assessments*. U.S. Department of Commerce.

National Institute of Standards and Technology. (2010). *SP 800-34 Rev. 1: Contingency Planning Guide for Federal Information Systems*. U.S. Department of Commerce.

National Institute of Standards and Technology. (2020). *SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations*. U.S. Department of Commerce.

Microsoft Corporation. (2024). *Active Directory Domain Services Overview*. Microsoft Learn.
Microsoft Corporation. (2024). *Active Directory Backup and Disaster Recovery*. Microsoft Learn.

Snedaker, S. (2013). *Business Continuity and Disaster Recovery Planning for IT Professionals* (2nd ed.). Syngress.

Whitman, M. E., & Mattord, H. J. (2021). *Principles of Information Security* (7th ed.). Cengage Learning.